UNITÀ 1 · CYBERSECURITY · LEZIONE 2

La cybersecurity in azienda

Asset, rischio, framework e leggi: come un'azienda decide che cosa proteggere prima, con quanti soldi e chi ne risponde.

5G TPSI Analisi del rischio, ISO 27001, NIST CSF, NIS2, ACN

PER COMINCIARE

Una pizzeria con ordini online: quale perdita fa più male?

SONDAGGIO

- **A** I dati delle carte dei clienti rubati
- **B** Il sito fermo il sabato sera
- **C** La ricetta dell'impasto copiata
- **D** Recensioni false che rovinano la reputazione

DOVE ERAVAMO RIMASTI

Dalla teoria all'azienda vera

Lo sappiamo già

- Triade CIA e i sei principi (*principi-sicurezza*)
- Vulnerabilità, minaccia, attacco, rischio (*attacchi-informatici*)
- Difesa in profondità e backup 3-2-1 (*difese-informatiche*)

Oggi aggiungiamo

Quanto vale ogni asset

Come si misura e si sceglie il rischio da trattare

Framework e leggi che l'azienda deve rispettare

Un'azienda ha un budget limitato: la sicurezza è una **scelta di priorità**, non una lista di tutto ciò che si potrebbe fare.

PASSO 1 · INVENTARIO

Non puoi proteggere ciò che non sai di avere

Informazioni

Dati dei clienti, contabilità, progetti, contratti, credenziali.

Sistemi

Server, PC, telefoni, rete, software, servizi cloud, sito web.

Persone e fornitori

Dipendenti, competenze, il tecnico esterno, il provider, il gestionale in cloud.

PASSO 2 · STIMA

Il rischio si calcola

Una stima semplice, molto usata

$$R = P \times I$$

- **P**, probabilità che la minaccia sfrutti la vulnerabilità: da 1 (rara) a 5 (quasi certa).
- **I**, impatto sull'azienda: da 1 (trascurabile) a 5 (fallimento, danni gravi a persone).
- Si decide prima la soglia: per esempio alto da 15, medio da 8.

P \ I	1	2	3	4	5
5	5	10	15	20	25
4	4	8	12	16	20
3	3	6	9	12	15
2	2	4	6	8	10
1	1	2	3	4	5

QUIZ A TRABOCCHETTO

Un backup offline, provato ogni mese, riduce soprattutto...

QUIZ

A la probabilità di subire un ransomware

B la vulnerabilità dei PC

C il numero di attaccanti interessati

D l'impatto di un ransomware

AL COMPUTER · 25 minuti

Il registro dei rischi in Calc

	A	B	C	D	E
1	Asset	Minaccia	P	I	R
2	E-mail	Phishing	4	4	=C2*D2

In F2: `=SE(E2>=15;"Alto";SE(E2>=8;"Medio";"Basso"))`

1. Scegli un'azienda: pizzeria online, studio dentistico o officina.
2. Compila almeno 8 righe, con asset e minacce diverse.
3. Ordina per R decrescente e colora le righe Alto.
4. Salva come **registro-rischi-cognome.ods**.

Controllo: la riga di esempio dà R = 16 e livello **Alto**. Con P = 2 e I = 4 ottieni 8, cioè **Medio**; con P = 2 e I = 3 ottieni 6, **Basso**.

PASSO 3 · TRATTAMENTO

Quattro modi di trattare un rischio

Mitigare

Si applicano contromisure che abbassano P o I.

Trasferire

Si sposta il danno economico su altri: assicurazione, fornitore.

Evitare

Si rinuncia all'attività che crea il rischio.

Accettare

Si decide consapevolmente di non fare nulla, e lo si scrive.

Dopo il trattamento resta sempre un **rischio residuo**: la direzione lo deve conoscere e approvare.

PUZZLE

Abbina ogni scelta al tipo di trattamento

Mitigare	---	Preparare un sito di emergenza che si attiva in un'ora
Trasferire	---	Smettere di conservare i numeri delle carte dei clienti
Evitare	---	Lasciare il vecchio PC della sala d'attesa, scollegato e senza dati
Accettare	---	Attivare la MFA su tutte le caselle di posta
Mitigare l'impatto	---	Stipulare una polizza che copre i costi di un incidente

QUANTO POSSIAMO RESTARE FERMI?

RTO e RPO: due numeri che decidono il backup

Quanti dati, misurati in tempo, puoi permetterti di perdere.

RPO di 24 ore: basta un backup al giorno. RPO di 15 minuti: serve una replica quasi continua.

Il tempo massimo di fermo accettabile.

Se il sito di e-commerce ha RTO di 4 ore, entro 4 ore deve ripartire, anche su un server di riserva.

Si ricavano dalla **BIA**, la Business Impact Analysis: per ogni processo, quanto costa un'ora di fermo.

AL COMPUTER · 25 minuti

Il registro dei rischi in Java

```
record Rischio(String asset, String minaccia,
               int p, int i) {
  int valore() { return p * i; }
  String livello() {
    int v = valore();
    return v >= 15 ? "ALTO" : v >= 8 ? "MEDIO" : "BASSO";
  }
}
// nel main: List<Rischio> registro con 5 rischi, poi
registro.sort(Comparator
    .comparingInt(Rischio::valore).reversed());
for (Rischio r : registro)
  System.out.printf("%-6s %2d  %s - %s%n", r.livello(),
      r.valore(), r.asset(), r.minaccia());
```

In **RischiTop.java** metti nel registro questi 5 rischi (asset, minaccia, P, I), poi esegui:

- Sito e-commerce, Ransomware sul server, 3, 5
- Database clienti, SQL injection, 2, 5
- PC cassa, Guasto del disco, 3, 2
- Account e-mail, Phishing, 4, 4
- Wi-Fi ospiti, Accesso non autorizzato, 2, 2

Controllo: la prima riga è `ALTO 16 Account e-mail - Phishing`, l'ultima ha il valore più basso.

NON SI INVENTA DA ZERO

Tre framework per organizzare la sicurezza

ISO/IEC 27001

Norma internazionale per un **sistema di gestione** della sicurezza delle informazioni (ISMS). Un'azienda si può **certificare**.

Ciclo continuo: pianifica, fai, verifica, agisci.

NIST CSF 2.0

Framework statunitense del 2024, usato in tutto il mondo. Sei funzioni:

Govern, Identify, Protect, Detect, Respond, Recover

Framework Nazionale

Il **Framework Nazionale per la Cybersecurity e la Data Protection**, adattamento italiano del NIST CSF, pensato anche per le PMI.

PUZZLE

Il ciclo di gestione del rischio: metti in ordine

1. Stimare probabilità e impatto, calcolare il rischio
2. Definire il contesto e i criteri: soglie, chi decide
3. Fare l'inventario degli asset e dei loro proprietari
4. Individuare minacce e vulnerabilità per ogni asset
5. Monitorare e rivedere, almeno una volta l'anno
6. Scegliere il trattamento e approvare il rischio residuo

AL COMPUTER · 20 minuti

Ogni misura nella sua funzione NIST

In un documento **csf-cognome** crea una tabella con le 6 funzioni del CSF 2.0 e colloca queste 12 misure. Salva come PDF.

- responsabile della sicurezza
- inventario dei PC
- MFA
- formazione anti-phishing
- backup cifrati
- allarmi dell'EDR
- analisi dei log
- isolare un PC infetto
- avvisare il CSIRT
- ripristino dai backup
- lezioni apprese
- policy approvata dalla direzione

Controllo: Govern 2, Identify 2, Protect 3, Detect 2, Respond 2, Recover 1. Se un tuo conteggio è diverso, scrivi accanto il perché: alcune misure sono discutibili.

LE REGOLE DEL GIOCO

Leggi e autorità che un'azienda italiana deve conoscere

Norma	Che cosa chiede
GDPR Reg. UE 2016/679	Sicurezza adeguata dei dati personali; violazioni notificate al Garante entro 72 ore
NIS2 Dir. UE 2022/2555, in Italia D.Lgs. 138/2024	Gestione del rischio, misure di sicurezza, notifica degli incidenti significativi per i soggetti essenziali e importanti
ACN Agenzia per la Cybersicurezza Nazionale, dal 2021	Autorità nazionale per la NIS2; ospita il CSIRT Italia, che riceve le notifiche

La NIS2 riguarda in genere le **medie e grandi** imprese di settori come energia, trasporti, sanità, acqua, infrastrutture digitali, manifattura, e la Pubblica Amministrazione.

QUIZ

Secondo la NIS2, chi risponde delle misure di sicurezza?

QUIZ

A Solo il responsabile IT, che le applica

B Gli organi di amministrazione, che le approvano e ne rispondono

C Il fornitore cloud, se i dati sono da lui

D L'ACN, che le controlla

METTERE TUTTO PER ISCRITTO

Le policy: le regole interne dell'azienda

- **Uso accettabile** di PC, posta e Internet
- **Password e accessi**: MFA, account personali, revoca a fine rapporto
- **Backup**: che cosa, quando, chi prova il ripristino
- **Dispositivi personali** (BYOD) e lavoro da remoto
- **Gestione degli incidenti**: chi chiamare, entro quando



MENTI CHE CI HANNO PRECEDUTO

Un processo, non un acquisto

> **La sicurezza è un processo, non un prodotto.**
>
> **Bruce Schneier**, crittografo ed esperto di sicurezza statunitense, prefazione di *Secrets and Lies*, 2000

All'esame. Se ti chiedono di "mettere in sicurezza" un sistema, non elencare prodotti: parti dagli asset, stima i rischi principali, scegli le contromisure e spiega come verifichi nel tempo che funzionino.

BIGLIETTO D'USCITA

Completa prima di uscire

Con probabilità 3 e impatto 5 il rischio vale ____.

Stipulare un'assicurazione cyber significa _____ il rischio.

La quantità massima di dati che posso perdere, misurata in tempo, si chiama _____.

La sesta funzione aggiunta nel NIST CSF 2.0 si chiama _____.

In Italia l'autorità nazionale per la NIS2 è l'_____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Inventario degli asset, con un proprietario
- R = P × I, con soglie decise prima
- Mitigare, trasferire, evitare, accettare
- RTO e RPO guidano backup e continuità
- ISO 27001, NIST CSF 2.0, Framework Nazionale
- GDPR, NIS2 e ACN: la direzione ne risponde
- Policy scritte, anche sull'AI
- Prossima lezione: chi sono gli attaccanti

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.